

Halden Distribution Ltd. — Incident Response Plan

Version: 1.0 (draft for approval) · **Owner:** IT (Muhammad Ibrahim Akmal) **Approver:** Managing Director (*unsigned — awaiting review*) · **Date:** 2026-10-02 **Alignment:** NIST SP 800-61r3 and NIST CSF 2.0 (Govern · Identify · Protect · Detect · Respond · Recover) **Companion runbook:** `../docs/runbooks/incident-response.md` · **Severity matrix:** `../configs/alert-severity-triage.csv`

1. Purpose and scope

This plan says how Halden detects, responds to and recovers from a security incident, and who decides what. It covers incidents affecting availability, confidentiality or integrity of Halden systems: ransomware, account compromise, data loss, lost devices, and serious outages. It applies to all staff, IT, and the external parties we depend on (insurer, legal, IR retainer).

Out of scope: routine faults handled by the service desk, and anything outside the lab environment described in the technical project documentation.

2. Objectives

- 1. **Detect** incidents early — before the damage is done where possible.
- 2. **Contain** them so they do not spread.
- 3. **Recover** the business to a known-good state from **verified** backups.
- 4. **Learn** from every incident so the next one is smaller.
- 5. **Communicate** honestly and on time to staff and management.

3. Governance and roles

Role	Who	Responsibility
Management decision-maker	Managing Director	Payment, disclosure, downtime, legal/regulator decisions
Incident Lead	IT Manager (or the most senior IT person available)	Runs the incident, decides severity, coordinates
Technical lead	On-call analyst	Works the evidence, contains, eradicates, recovers
Communications	Nominated IT + management contact	Staff/customer/press messages, keeps the update schedule
Scribe	Any available IT member	Owns the timeline and the evidence log
External	Insurer, legal counsel, IR retainer	Engaged per §6 and the contact tree

At Halden's size one person may hold several roles; the plan says who **would** do each job, and the gap is stated honestly rather than hidden.

4. Severity definitions

Severity is set by **business impact**, not by the alert's technical level.

Severity	Definition	Examples	Response target	Who is told
SEV1 — Critical	Active compromise of a Tier 0 system, ransomware executing, or data loss with business impact	Ransomware, Domain Admins compromise, DCSync	Immediate, 24×7	MD within 15 min; insurer ASAP
SEV2 — High	Confirmed account compromise, or malware contained on one host	Compromised user account, malware isolated to one PC	< 1 hour	IT Manager, department head
SEV3 — Medium/Low	Suspicious activity or a policy violation, no confirmed impact	Odd logon, single blocked file	< 1 business day	IT

Severity can be raised or lowered as facts change, and every change is recorded in the timeline with who changed it and why.

5. Escalation and on-call

Step	From	To	Trigger
1	Service desk (L1)	IT analyst (L2)	Cannot resolve, or a security alert
2	IT analyst	Incident Lead	SEV2 confirmed, or any SEV1
3	Incident Lead	Managing Director + IR retainer	SEV1, or containment not certain within 30 min
4	Incident Lead	Insurer / legal / regulator	On legal advice, per §6 deadlines

Full matrix with channels: `../configs/escalation-oncall-matrix.csv` . Real contact details live in the owner's password manager and are never committed to this repository.

6. External contacts and notification deadlines

Party	Purpose	Deadline / note
IR retainer	Forensic and containment help	Engaged on SEV1
Cyber insurer	Claim and approved-vendor support	As soon as SEV1 is confirmed
Legal counsel	Disclosure and liability questions	Before notifying any authority or customer
Regulator	Data-protection breach notification	Pakistan: PECA 2016 and any sector regulator (e.g. SBP for banks); check the status of the Personal Data Protection Bill. EU customers: 72 hours under GDPR
Police / national CERT	Reporting a criminal act (PKCERT)	On legal advice

Notifications to authorities are **never** sent without legal advice. The name-and-shame risk of a wrong notification is a management decision.

7. Communication templates

Staff notice (plain language):

We are dealing with a security incident affecting [service]. You may notice [symptom]. Please do [action]. We will update you by [time]. Do not discuss this outside the company until we say so.

Management update (SEV1):

Incident [ID], severity SEV1. What we know: [facts]. Impact: [business impact]. Action taken: [containment]. Decision needed: [yes/no, and what]. Next update: [time].

Customer notice (on legal advice only):

We are aware of an incident affecting [service]. We have taken steps to [action]. We will contact affected parties as our investigation continues.

Never speculate. State facts, state the next update time, and keep to it.

8. Evidence handling

- Preserve before you clean up: memory, logs, suspicious files, the state of group memberships.
- Keep a chain-of-custody table in the incident record (what, who, when, hash).
- One authoritative timeline in UTC; everyone writes to the same one.
- Sanitize before anything is shared outside the incident team; raw Wazuh archives and full alert

dumps are never published (they stay in `evidence/raw/`, which is not committed).

9. Testing and maintenance

- **Tabletop exercise** at least once a year: `p07-tabletop-exercise.md`.
- **Playbooks** reviewed after every real incident and every tabletop.
- **Detection coverage** measured with an authorised lab test (`scripts/07`); a rule that does not

fire is recorded honestly.

- This plan is reviewed annually, or after any SEV1.

10. Plan maintenance and approval

Field	Value
Author	Muhammad Ibrahim Akmal (IT)
Version	1.0 draft
Approver	Managing Director
Approval date	<i>(blank — unsigned until reviewed)</i>

Field	Value
Next review	12 months from approval

Approval

Role	Name	Signature	Date
Managing Director			
IT Manager (Incident Lead)			

Halden Distribution Ltd. is a fictional company for a home-lab portfolio project. The plan, its content and any measurements are real work; the named approvers and their signatures are simulated, and the approval block is deliberately left unsigned.